

Vulnerability Assessment Report

1st January 20XX

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

The database server is a critical asset that stores and manages customer and business data used for daily operations and decision-making. Because it is publicly accessible, it is highly vulnerable to unauthorized access, which could result in data breaches or data manipulation. Securing this server is essential to protect sensitive information, maintain customer trust, and comply with data protection standards. If the server were disabled or compromised, employees would lose access to vital data, disrupting operations and potentially causing financial and reputational damage.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
External attacker	Unauthorized access and data breach	3	3	9
Malicious insider		2	3	6

	<i>Data exfiltration or misuse of information</i>			
<i>Competitor / botnet</i>	<i>Distributed Denial of Service (DDoS) attack</i>	<i>2</i>	<i>2</i>	<i>4</i>

Approach

The risks were selected based on the system's public exposure and its importance to business operations. External attackers present the highest risk due to the lack of proper access controls, making unauthorized access highly likely and severe in impact. Insider threats were considered because employees have direct access to sensitive data, increasing the risk of misuse or accidental exposure. A denial-of-service attack was also included, as it could disrupt access to the database and halt business activities. These risks were prioritized because they directly affect confidentiality, integrity, and availability of the system.

Remediation Strategy

The organization should immediately restrict public access to the database server and implement strict access controls based on the principle of least privilege. Multi-factor authentication (MFA) and strong password policies should be enforced to secure user accounts. A defense-in-depth approach should be adopted, including firewalls, intrusion detection systems, and continuous monitoring. Additionally, replacing outdated SSL with modern TLS encryption ensures secure data transmission. Implementing an Authentication, Authorization, and Accounting (AAA) framework, along with IP allow-listing, will further reduce unauthorized access and improve system accountability.